

trust boundary — single Docker bridge network; the resource server is not published to the host

Keycloak 26.4.4 — identity provider

realm profile: FAPI 2.0 DPoP · PAR, PKCE (S256)
issues access tokens carrying `cnf.jkt`, 300 s lifetime

JWKS

Zero Trust Controller — PEP + PDP (FastAPI, port 9000)

1 token_verify

JWKS signature · issuer · expiry · `cnf.jkt` present

2 dpop_verify (RFC 9449)

ES256 JWS · RFC 7638 thumbprint = `cnf.jkt` · `htm` / `htu`
iat within ± 60 s · `jti` replay cache · `ath`

3 telemetry + device registry (PIP)

per-subject 60 s window: call rate, geo velocity,
session continuity, DPoP-failure rate
registry: has this subject used this `cnf.jkt` before?

4 risk

six additive rules $\rightarrow$ risk $\in [0,1]$, belief $b = 1 - \text{risk}$

6 enforce

ALLOW $\rightarrow$ proxy · CHALLENGE $\rightarrow$ 401 · DENY $\rightarrow$ 403

stages each configuration executes

B0 stage 6 only — plain bearer, no policy

B1 stages 1, 2, 6 — FAPI 2.0 / DPoP baseline

P stages 1-6 — B1 plus continuous enforcement
one image; the configuration is selected by environment flags

5 OPA 0.70.0 — `zt.rego`

hard deny on any failed mandatory check; otherwise
ALLOW / CHALLENGE / DENY by comparing risk to
 $\tau_{\text{allow}} = 0.40$ and $\tau_{\text{deny}} = 0.70$; unreachable $\rightarrow$ DENY

all continuous-trust state is keyed on the
verified *sub* claim and on `cnf.jkt`, never
on a client-supplied header

the controller strips Authorization and DPoP and asserts
the verified subject on an internal service header

Mock ADR API (Basiq-isomorphic)

/users /accounts /transactions /consents

object-level ownership enforced on every object
synthetic data, seed 42: 100 users $\times$
3 accounts $\times$ 200 transactions
reachable only through the controller

(1) token request
(DPoP-bound)

Client
EC P-256 key pair
signs one DPoP proof
per request

untrusted

(2) API request:
Authorization + DPoP